NoteMD — Processor Documentation Pack

Prepared: 26 August 2026 · **Revised:** 15 October 2026 · **Prepared by:** Development team **Purpose:** Supporting artefacts for NoteMD's DPIA, DSPT and DTAC submissions.

These are the three documents a processor is normally expected to supply to a controller. They are written to be pasted directly into your own templates.

Companion documents:

- `TECHNICAL-ARCHITECTURE.md` — full 15-point technical review
- `architecture-diagram.html` — data flow map
- `GDPR-STATUS.md` — compliance status and gaps

> *Technical evidence prepared by the development team. Not legal advice. The lawful basis, Article 9 condition and transfer risk assessments require sign-off by a data protection officer.*

---

0. Controller / processor roles

This needs stating explicitly in the DPIA, because NoteMD holds **two different roles** depending on the data:

DATA	CONTROLLER	PROCESSOR
Patient audio, transcripts, letters, patient identifiers	The NHS body or private clinic employing the clinician	**NoteMD**
Clinician account data (name, email, password, billing)	**NoteMD**	Supabase, Stripe

So NoteMD is a **processor** for clinical data and a **controller** for its own user accounts. The obligations differ, and a reviewer will look for this distinction.

---

1. Sub-processor register

Article 28(2) and 28(4). This is the list a controller must be given, and must be notified about when it changes.

#	SUB-PROCESSOR	SERVICE PROVIDED	DATA CATEGORIES PROCESSED	PROCESSING LOCATION	TRANSFER SAFEGUARD	RETENTION BY SUB-PROCESSOR
1	**Supabase** (Supabase Inc.)	Database, file storage, authentication, serverless functions	Patient audio, transcripts, generated letters, uploaded context documents, patient identifiers, clinician account data	`eu-west-1` — Ireland	Within EEA; no transfer mechanism required	For the life of the account; audio and context documents auto-deleted at the configured retention period (default 30 days)
2	**AssemblyAI** (AssemblyAI, Inc.)	Real-time speech-to-text — **primary engine** for consultations and standard dictation	Consultation audio only — no patient identifiers transmitted	EU Data Zone — `streaming.eu.assemblyai.com`; processed in EU AWS regions only	Within EEA. Audio processed in the European data zone is excluded from model training under vendor policy	Vendor policy — **written confirmation outstanding**
3	**Deepgram** (Deepgram Inc.)	Real-time speech-to-text — **automatic fallback** if AssemblyAI cannot open a session	Consultation audio only — no patient identifiers transmitted	`eu-central-1` — Frankfurt	Within EEA. `mip_opt_out=true` sent on every request, excluding audio from retention and model training	Not retained; opt-out applied per request and enforced in code
4	**Microsoft Azure OpenAI** (Microsoft Ireland Operations Ltd.)	Enhanced dictation transcription, clinical letter generation, context document summarisation	Dictation audio, consultation transcripts, patient name, uploaded context documents and page images, template prompts	**France Central** — resource `notemd-eu`	Within EEA; no transfer mechanism required	Azure OpenAI abuse-monitoring policy; not used for model training
5	**Microsoft Azure Communication Services** (Microsoft Ireland Operations Ltd.)	Transactional email delivery of letters and transcripts	Generated letters, transcripts, patient identifiers, recipient addresses	**United Kingdom** — resource data location	Within UK	Vendor policy
6	**Render** (Render Services Inc.)	Static frontend hosting	**No patient data.** Serves the application	To be confirmed	DPA in vendor terms	Platform default

#	SUB-PROCESSOR	SERVICE PROVIDED	DATA CATEGORIES PROCESSED	PROCESSING LOCATION	TRANSFER SAFEGUARD	RETENTION BY SUB-PROCESSOR
			bundle only. Access logs may contain IP addresses.			
7	**Stripe** (Stripe, Inc.)	Subscription billing	**No patient data.** Clinician name, email, payment details — card data goes browser-to-Stripe and never touches NoteMD systems.	Global	DPA + SCCs	Stripe policy
8	**Valoco / development contractor**	Application development and maintenance	Administrative access to production infrastructure; may incidentally view clinical data during support	United Kingdom	Contract between NoteMD and contractor	No separate copies retained

Notes for the controller

- **No patient data now leaves the EEA or the UK.** This is the material change since the August version of this pack, where OpenAI's global endpoint was the one route out and was listed as the highest risk on the register. Transcription, letter generation and email all now process within the EEA or the UK, and every location in the table above has been verified from the provider's own response headers rather than from configuration — see `evidence/azure-openai-cutover.md` and `evidence/assemblyai-residency.md`.
- **Entries 2 and 3 are enforced in the browser, not only on the server.** The Content Security Policy names each vendor's EU host and omits their global ones, so a misconfiguration pointing at a non-EU endpoint results in a refused connection rather than audio quietly leaving the EEA. This matters most for AssemblyAI, whose default endpoint edge-routes to the nearest region including the United States.
- **Entry 4 covers three distinct uses** of one resource: transcription, letter generation, and summarising uploaded documents. They use different deployments on the same resource and are listed together because the processor, location and safeguard are identical.
- **Entry 8** is included deliberately. A development contractor with production access is a sub-processor and reviewers expect to see it listed, even though it is often omitted.
- **OpenAI, Resend, Google Cloud Platform and Hugging Face are no longer sub-processors.** OpenAI was replaced by entry 4 on 5 October 2026; Resend by entry 5; the Google Cloud speech service has been decommissioned. Hugging Face was never sent personal data — it supplied model weights to that service during container build. Controllers notified of the August list should be told these four have been removed and entries 2, 4 and 5 added.
- **No analytics, telemetry or error-reporting service is in use** — verified against the application's dependencies.

2. Record of processing activities

Article 30(2) — the record a processor maintains of processing carried out on behalf of controllers.

Processor: NoteMD (Clinical Documentation Solutions) **Controllers:** NHS bodies and private clinics whose clinicians hold accounts **Data protection officer:** *[to be completed by NoteMD]*

2.1 Categories of processing carried out on behalf of controllers

ACTIVITY	DESCRIPTION	DATA CATEGORIES	DATA SUBJECTS
Audio capture	Recording of consultations and dictation	Voice recordings	Patients, clinicians
Speech-to-text	Conversion of audio to text	Voice recordings → clinical text	Patients
Letter generation	Structuring of transcript into a clinical letter	Clinical text, patient identifiers	Patients
Storage	Retention of transcripts, letters and audio	All of the above	Patients
Delivery	Optional email of letters and transcripts	Letters, transcripts, identifiers	Patients, recipients

2.2 Special category data

Health data — **UK GDPR Article 9(1)**. Processing condition to be recorded by the controller; **Article 9(2)(h)** (health and social care) is the expected basis. *Confirmation required from the DPO.*

2.3 Categories of data subject

Patients; clinicians; medical secretaries with delegated access; letter recipients.

2.4 Transfers to third countries

RECIPIENT	COUNTRY	MECHANISM	STATUS
Stripe	United States	SCCs + UK Addendum	Active — no patient data
Render	To be confirmed	DPA in vendor terms	Active — no patient data

No restricted transfer of patient data currently takes place. Transcription, letter generation, document summarisation and email all process within the EEA or the UK. The only sub-processors outside the UK/EEA are Stripe and Render, neither of which receives patient data. | Google Cloud (idle) | United States | SCCs + UK Addendum | No data flowing |

All other processing takes place within the EEA.

2.5 Security measures

See section 3.

2.6 Retention

DATA	RETENTION	MECHANISM
Patient audio	30 days (configurable 1–3650 per clinician)	Automated nightly deletion
Transcripts	10 years by default, aligned to NHS records retention	Deleted on controller instruction
Generated letters	10 years by default	Deleted on controller instruction
Locally cached transcript	24 hours maximum	Cleared at sign-out
Audit records	Retained indefinitely for accountability	Contains no clinical content
Backups	Platform-managed	*To be confirmed against the Supabase plan*

3. Technical and organisational measures

Article 32. Structured to the sub-paragraphs of Article 32(1).

3.1 Pseudonymisation and encryption — Art. 32(1)(a)

MEASURE	IMPLEMENTATION
Encryption in transit	TLS 1.2+ on all connections, including to every sub-processor
Encryption at rest	AES-256 for database and file storage (platform-provided)
Credential storage	Passwords hashed with bcrypt by the authentication provider
Secrets management	API keys held in server-side environment configuration; **no secret keys present in the client application**
Streaming credentials	Short-lived tokens minted server-side per session, never persisted in the browser

Pseudonymisation is not currently applied — patient identifiers are stored alongside clinical content because they must appear in the generated letter.

3.2 Confidentiality, integrity, availability, resilience — Art. 32(1)(b)

Confidentiality

MEASURE	IMPLEMENTATION
Tenant isolation	Row Level Security on every table, enforced in the database rather than in application code, so it cannot be bypassed by a malformed client request
File isolation	Storage objects scoped to a per-user path prefix; the bucket is private with no public read
Delegated access	Medical secretaries reach only their assigned clinician's records, via a constrained database function
Device hygiene	All patient data cached in the browser is removed at sign-out, including residue from previous users on shared workstations
Logging discipline	Clinical content is excluded from application logs; logging is limited to counts, status codes and timings

Integrity

MEASURE	IMPLEMENTATION
Transcript integrity	A transcript displayed for review is marked authoritative; the system will not re-run speech recognition and substitute different text. The letter is generated from exactly the words the clinician approved.
Clinical scope limits	The letter-generation prompt forbids introducing diagnoses, medication, investigations or advice not present in the source, and requires uncertainty to be preserved
Clinician sign-off	Every letter is reviewed and approved by the clinician before use
Audit record	Append-only; no client-side write path

Availability and resilience

MEASURE	IMPLEMENTATION
Managed infrastructure	Platform-provided redundancy and failover
Connection loss	Audio recording continues locally through network interruption; transcription reconnects automatically and the recording is preserved
Work-in-progress protection	Sessions autosave approximately every 15 seconds and on navigation away, so an interrupted consultation is recoverable

3.3 Restoring availability — Art. 32(1)(c)

Managed backups provided by the platform, inheriting the EEA region and encryption at rest. **Plan, retention window, point-in-time recovery status and restoration procedure to be confirmed by NoteMD.**

3.4 Testing and evaluation — Art. 32(1)(d)

MEASURE	STATUS
Automated test suite (102 tests) covering access isolation, transcript integrity, schema conformance and interface hygiene	In place, runs on every change
Structural security review of the architecture	Completed August 2026
Independent penetration test	**Not yet commissioned**
Dependency vulnerability scanning	**Not yet implemented**

3.5 Data subject rights support

RIGHT	MECHANISM
Access / portability (Art. 15, 20)	Structured export of all data held for a user account
Erasure (Art. 17)	Deletion of records, letters and stored audio, with the erasure itself recorded in the audit log
Rectification (Art. 16)	Clinicians can edit transcripts and letters directly
Restriction (Art. 18)	Manual, by controller instruction

Limitation to declare: current tooling operates per **clinician account**. Locating and deleting a **single patient's** records requires a manual database operation. This is on the development roadmap and is likely to be raised in a DPIA.

4. Known limitations

Declared openly, as a reviewer will find them:

#	LIMITATION	IMPACT
1	~~Patient data is transmitted to OpenAI outside the EEA and may be retained up to 30 days~~	**CLOSED, 5 October 2026.** Replaced by Azure OpenAI in France Central; verified from the provider's own `x-ms-region` response header
2	No per-patient deletion	Erasure requests need manual handling
3	No multi-factor authentication	Will be queried for special category data
4	Audit trail does not yet cover logins, record access or letter generation	Structure exists; event coverage is limited
5	No password reset flow	Operational, not a data protection issue
6	No separate staging environment	Development operates against production infrastructure
7	No independent penetration test	Expected for DTAC
8	Web fonts served from a US CDN, transmitting clinician IP addresses	Personal data, not patient data

5. Scope boundary

The following are **not development deliverables** and cannot be produced by the development team. They are listed so responsibilities are unambiguous.

ITEM	OWNER	WHY
The DPIA itself	NoteMD / DPO	The assessment of necessity, proportionality and risk to data subjects is the controller's, informed by this pack
Lawful basis and Article 9 condition	DPO	A legal determination
DSPT submission	NoteMD IG lead	An organisational assertion, not a technical one
DCB0129 clinical safety	NoteMD **Clinical Safety Officer**	The standard requires a named CSO who is a registered clinician with clinical risk management training. The Clinical Risk Management Plan, Hazard Log and Clinical Safety Case Report must be authored and signed by that person. Development can supply technical input to the hazard analysis but cannot own or sign these documents.
Penetration test — procurement and management	NoteMD	Must be an independent third party to have any assurance value; engaging and managing the tester sits with the organisation
Remediation arising from the penetration test	Scoped separately	Findings are unknown until the test reports; effort cannot be estimated in advance and is not covered by existing development scope
Sub-processor contracts (DPAs, OpenAI Zero Data Retention, EU-resident project, Deepgram retention confirmation)	NoteMD	Commercial agreements requiring signature by the data controller
Transfer risk assessments	DPO	Written assessments, not supplied by any vendor
Privacy notices for patients	Controller organisations	Patient-facing communication

Additionally, several items in the technical request are **new feature development rather than documentation** — per-patient deletion, multi-factor authentication, audit trail expansion, password reset, a staging environment and automated cross-user access testing. These are scoped and quoted separately from documentation work.